1. AISecproxy

Instrukcja użytkownika

- *Wstęp*
- *Konfiguracja*
- *Wdrożenie*
- *Analizowane typy treści*
- *Analiza logów*

2. Wstęp

AISecproxy jest serwisem/aplikacją realizującą funkcję HTTP/HTTPS proxy oraz umożliwiającą oraz analizę, monitorowanie i modyfikowanie ruchu HTTP/HTTPS.

Kluczowe funkcje

- Analiza ruchu HTTP/HTTPS wraz z prezentacją szczegółowych informacji o żądaniach i odpowiedziach w interfejsie webowym (opcja).
- Ścisła integracja z systemem Secure Web Intelligence!
- Mechanizm wtyczek (pluginów), pozwalający w prosty sposób rozszerzać funkcjonalność aplikacji.
- Obsługa certyfikatów HTTPS . Certyfikaty przechowywane są w katalogu `certs`. Jeśli certyfikat główny (root CA) został wcześniej zaufany podczas korzystania z AIsecproxy, może używać go bez dodatkowej konfiguracji.
- Wsparcie dla protokołu HTTP/2.

AISecproxy dedykowany jest do uruchomienia w środowisku Docker. Dzięki temu unikamy komplikacji związanej z niekompatybilnością bibliotek czy wrażliwości na aktualizacje systemu. Przykładowy proces wdrożenia opisany jest w kolejnych rozdziałach.

3. Konfiguracja

Konfiguracja AISecproxy znajduje się w pliku aiseproxy.json. W przypadku środowisku Docker należy utworzyć obiekt Config o przykładowej zawartości niżej, a następnie przekazać w pliku Compose dla serwisu (w następnym etapie):

```
{
  "Addr": "0.0.0.0:9080",
  "WebAddr": "0.0.0.0:9081",
  "SslInsecure": true,
  "IgnoreHosts": [
  ],
  "AllowHosts": [
  ],
  "CertPath": "certs",
  "Debug": 0,
  "Dump": "",
  "DumpLevel": 1,
  "Upstream": "",
  "UpstreamCert": true,
  "MapRemote": "",
  "MapLocal": "",
  "LogFile": "",
  "ProxyAuth": "",
  "loglevel": 5,
  "proxyMode": 1,
  "storageDir": "suricata",
  "redisAddr": "swiCache1:6379",
  "redisPassword": "",
  "redisDB": 0,
  "redisqueuename": "aiplat",
  "minSizeDumpTextFile": 1,
  "dumpallfileswithoutfiltering": false,
```

```
  "dumprequests": false,
  "convHtmlToTxtonDumping": false
}
```

Opis parametrów:

Addr - IP interfejsu oraz port, na którym AISecproxy nasłuchuje;

WebAddr - IP interfejsu oraz port, na którym nasłuchuje moduł webowego podglądu przepływu danych (opcja);

SslInsecure - czy weryfikować certyfikat SSL serwera docelowego (True, False);

IgnoreHosts - lista domen/hostów po przecinku, które będą ignorowane z mechanizmu rozszyfrowywania SSL (MITM) (string list);

AllowHosts - lista domen/hostów, po przecinku, dla których zachodzić ma mechanizm rozszyfrowywania SSL (MITM). UWAGA - jeśli lista jest pusta, AISecproxy wykonuje SSL inspection (MITM) dla każdego żądania i każdego docelowego hosta. Jeśli istnieje co najmniej jeden wpis, inspekcja jest wykonywana tylko dla danego hosta, a ruch do każdego innego nie jest analizowany! (string list);

CertPath - ścieżka do folderu z certyfikatami CA (root-ca.pem) oraz certyfikatem AISecproxy (aisecproxy-root-ca.pem). Certyfikat CA jest potrzeby do podpisywania generowanych w locie certyfikatów. aisecproxy-root-ca.pem jest certyfikatem proxy. Jeśli plików nie ma, zostaną utworzone z domyślnymi testowymi parametrami (string)

Debug - poziom szczegółowości logowania: 0 - brak dodatkowych informacji, tylko podstawowe, 1 - wyświetl pełne informacje typu Debug, 2 - wyświetl tylko informacje o połączeniach

Dump - nazwa pliku, do którego będą zapisywane proxowane nagłówk i/lub body;

DumpLevel - czy zapisywać do pliku tylko header (0), czy nagłówek + body (1) (liczba);

Upstream - nie ustawiamy;

UpstreamCert - nie ustawiamy. Musi zostać True;

MapRemote - nie ustawiamy;

MapLocal - nie ustawiamy;

LogFile - nazwa pliku, gdzie zapisywane są logi AISecproxy. Jeśli pusto, logi nie są zapisywane (string);

ProxyAuth - włącz autoryzację dla proxy. Należy wypełnić w postaci: "user:password" (string);

loglevel - nie ustawiamy, parametr nie używany;

proxyMode - tryb pracy proxy. 0 - działą jako proste proxy z rozszyfrowaniem ruchu https, 1 - tryb współpracy z SWI, 2 - tryb dump model, czyli zrzucane są wszystkie znane pliki MIME do folder określonego w StorageDir (liczba);

storageDir - katalog, gdzie zapisywane są zdekodowane pliki do dalszej inspekcji lub analizy przez SWI (string). Jest to folder w kontenerze, i jest to domyślnie /suricata. Tego nie należy zmieniać, a pamiętać, by zmapować prawidłowy katalog roboczy z docker hosta do /suricata;

redisAddr - w przypadku współpracy z SWI adres/nazwa usługi Redis (string);

redisPassword - hasło do usługi Redis (string);

redisDB - indeks bazy danych Redis, domyślnie 0 (liczba całkowita);

redisqueuename - nazwa kolejki redis, gdzie umieszczane są eventy do analizy dla SWI (string);

minSizeDumpTextFile - nie analizuje obiektu response body mniejszego niż ta wartość (liczba całkowita);

Dumpallfileswithoutfiltering - czy zrzucać do analizy wszystkie rodzaje plików, czy tylko znane typy MIME określone w pliku mime.ini (True, False);
dumprequests - czy analizować requesty (True, False);
convHtmlToTxtonDumping - czy konwertować zrzucany do analizy plik html na czysty tekst (True, False);

4. Wdrożenie

Wdrożenie należy wykonać w środowisku docker używając mechanizmu docker compose. Poniżej przedstawiono przykładowy deployment:

```
version: '3.8'

services:
  webproxy:
    image: b3repo.aiseclab.com:5000/ais/proxy/aisecproxy:2.0.1
    container_name: webproxy
    restart: always
    tty: true
    ports:
      - "9080:9080"
    configs:
      - source: aisecproxy3
        target: /aisecproxy.json
    deploy:
    volumes:
      - "/mnt/panthera_nfs/b3/suricata:/suricata"
    networks:
      - centrala_swarm
networks:
  centrala_swarm:
    name: centrala_swarm
    external: true
configs:
  aisecproxy3:
    external: true
```

Należy zwrócić uwagę, by:

- AISecproxy pracował w tej samej sieci overlay, co Redis lub Redis był dostępny po adresie zewnętrznym
- wyeksponować port proxy na zewnątrz: 9080
- Przekazać prawidłową konfigurację poprzez mechanizm Configs
- zmapować prawidłowo udział do /suricata (w trybie Bind)

Do zarządzania najlepiej użyć AIPlatform Management Console.

5. Analizowane typy treści

Oprócz standardowego pliku konfiguracyjnego aisecproxy.json występują jescze dwa pliki:

- mime.ini - plik określa, jakie typy MIME są domyślne analizowane w przypadku współpracy z SWI, lub zrzucane w przypadku pracy w trybie DUMP mode;
- mime_in_json.ini - określa typy MIME wartości, które są dołączane bezpośrednio do pliku JSON wysyłanego do kolejki Redis (zgodność z Suricata). To są tylko pliki tekstowe.

Domyślna zawartość pliku mime.ini:

```
image/jpeg=.jpg
image/jpg=.jpg
image/png=.png
image/apng=.apng
image/jp2=.jp2
image/avcs=.avcs
image/heic-sequence=.heic
image/heif=.heif
image/heif-sequence=.heif
image/hej2k=.hej2k
image/hsj2=.hsj2
image/gif=.gif
image/webp=.webp
image/svg+xml=.svg
image/bmp=.bmp
image/tiff=.tiff
image/heic=.heic
image/avif=.avif
image/x-icon=.ico
image/wmf=.wmf
image/vnd.microsoft.icon=.ico
image/x-ms-bmp=.bmp
image/x-portable-pixmap=.ppm
```

```
image/x-portable-graymap=.pgm
image/x-portable-bitmap=.pbm
image/x-xbitmap=.xbm
image/x-xpixmap=.xpm
video/mp4=.mp4
video/VP8=.webm
video/VP9=.webm
video/webm=.webm
video/ogg=.ogv
video/x-msvideo=.avi
video/x-matroska=.mkv
video/quicktime=.mov
video/mpeg=.mpeg
video/encaprtp=.rtp
video/iso.segment=.m4s
video/JPEG=.jpg
video/jpeg2000=.jp2
video/mj2=.mj2
video/MP1S=.mp1
video/MP2P=.mpg
video/MP2T=.ts
video/3gpp=.3gp
video/3gpp2=.3g2
video/x-flv=.flv
video/MP4V-ES=.mp4
video/MPV=.mpv
video/raw=.raw
video/vc1=.vc1
video/vc2=.vc2
video/x-ms-wmv=.wmv
video/av1=.av1
video/h261=.h261
video/h263=.h263
```

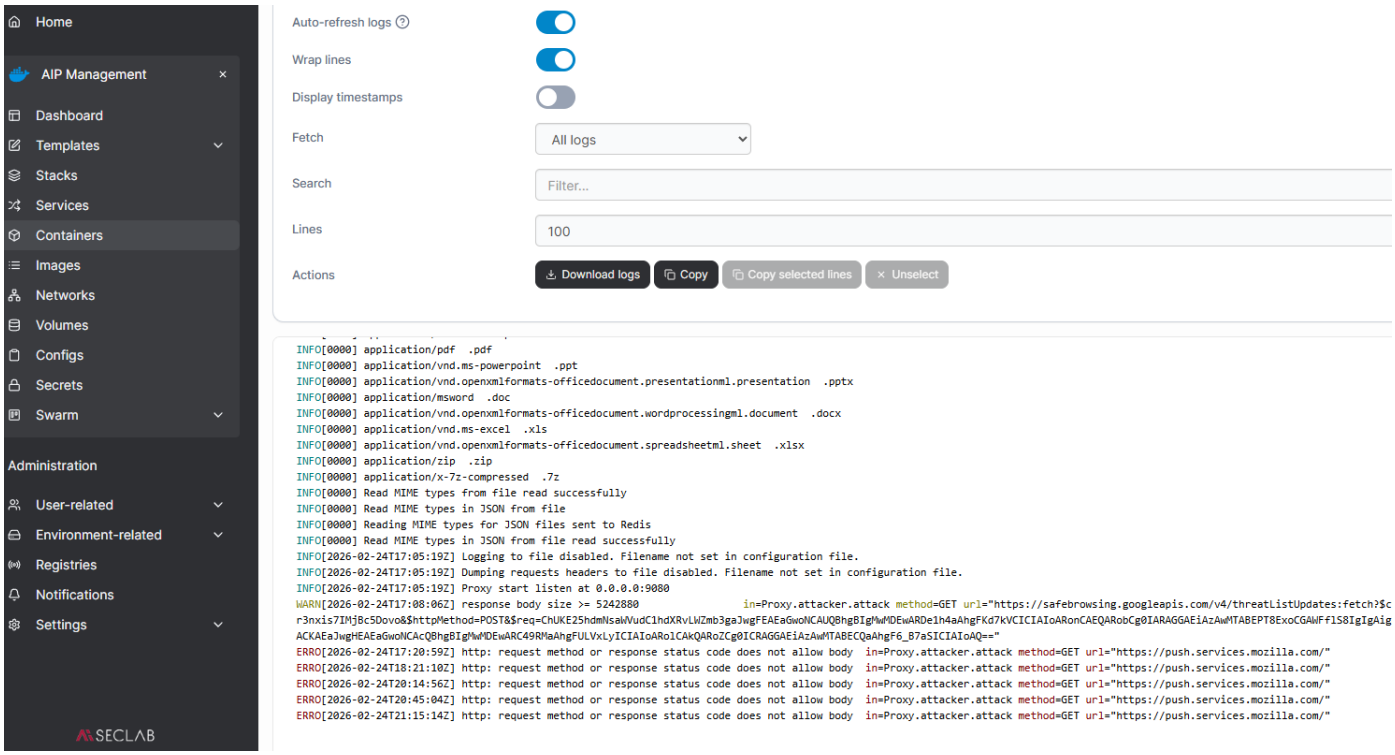
```
video/jpeg=.jpg
video/jpm=.jpm
video/mp2t=.ts
video/x-f4v=.f4v
video/x-fli=.fli
video/x-m4v=.m4v
video/x-ms-asf=.asf
video/x-ms-wm=.wm
video/x-ms-wmx=.wmx
video/x-ms-wvx=.wvx
video/x-sgi-movie=.movie
video/h264=.h264
video/h265=.h265
audio/mpeg=.mp3
audio/wav=.wav
audio/webm=.weba
audio/3gpp=.3gp
audio/aac=.aac
text/csv=.csv
text/plain=.txt
text/html=.html
text/markdown=.md
text/xml=.xml
text/rtf=.rtf
text/yaml=.yaml
text/yaml=.yaml
application/json=.json
officedocument.wordprocessingml.document=.doc
application/vnd.oasis.opendocument.text=.odt
application/pdf=.pdf
application/vnd.ms-powerpoint=.ppt
application/vnd.openxmlformats-officedocument.presentationml.presentation=.pptx
application/msword=.doc
```

```
application/vnd.openxmlformats-officedocument.wordprocessingml.document=.docx
application/vnd.ms-excel=.xls
application/vnd.openxmlformats-officedocument.spreadsheetml.sheet=.xlsx
application/zip=.zip
application/x-7z-compressed=.7z
```

Domyślna zawartość pliku mime_in_json.ini:

```
text/csv
text/plain
text/html
text/xml
application/json
application/xml
text/calendar
```

Można określić, które typy MIME mają być poddane inspecji już na etapie wstępnej analizy danych. W przypadku, gdy chcemy analizować wszystko, tj. cały ruch bez wyjątku, należy w pliku konfiguracyjnym aisecproxy.json ustawić dumpallfileswithoutfiltering=True.

6. Analiza logów

Logi serwisu są dostępne z AIP Management Console: